PENSE-BÊTE · RAPPORT ET STRATÉGIE

Cyberattaques DGFiP (2026)

00-10 ANSSI - Rapport d'incident sur les cyberattaques ayant touché la DGFiP (2026) — source : fiche de révision du module (gemma4, 01/11/2026 ; relu par Claude le 01/11/2026)

À RETENIR

1. L'attaquant **Zerobytes** a exploité des faiblesses d'**identité**, d'**architecture** et de **détection** pour exfiltrer des données sans être détecté.
2. **E-Contact** pillé en deux vagues (**11 Go** fin juin, **3 Go** fin juillet : 353 000 particuliers, 252 000 professionnels) ; incident distinct sur le **SPDC** (cadastre, « 2 millions de Français »).
3. L'attaquant est entré par le **RIE** depuis des infrastructures compromises de l'**Éducation nationale**, avec des identifiants volés par **infostealers** sur des appareils personnels.

Données exfiltrées et revendications

353 000
particuliers concernés (E-Contact)
données impots.gouv.fr

252 000
professionnels concernés (E-Contact)
données impots.gouv.fr

678 437
enregistrements annoncés par Zerobytes
session du 24 juin

2 000 000
Français concernés (données cadastrales)
SPDC, via le portail APEX (27 juillet-8 août)

Chronologie de l'attaque

2-8 mai un compte se connecte au **PIGP** depuis des IP malveillantes (France, Inde)

7 juin passage du PIGP au portail **ADER** depuis le RIE, non vu (ADER non supervisé)

9 juin le **COSSIM** (Éducation nationale) partage 17 marqueurs à tous les CSIRT

24-25 juin exfiltration E-Contact ; mot de passe réinitialisé mais **session non coupée**

22 juillet seconde exfiltration E-Contact (3 Go), compte réinitialisé le 23

27 juil.-8 août exfiltration du **SPDC** via le poste d'un géomètre-expert (APEX)

12-13 août **Zerobytes** revendique les vols ; ANSSI notifie la DGFiP

13 et 18 août coupure définitive d'ADER puis du PIGP pour les agents

Réactions qui n'ont pas arrêté l'attaque

Réaction	Pourquoi c'était insuffisant
7 juin : alerte (recherches sur la messagerie), compte réinitialisé	Le passage vers le portail **ADER** n'est pas vu : ADER n'était pas supervisé
24 juin, 10h40 : le SOC réinitialise le mot de passe	Ni la **session ouverte** ni l'exfiltration ne sont coupées (jusqu'au 25 juin, 2h31) ; 11 Go échangés du 22 au 25 juin
23-24 juillet : recherches suspectes détectées, compte réinitialisé, IP bloquée	3 Go déjà échangés
11 août : 5 comptes réinitialisés, 2 IP bloquées (signalées par l'ANSSI le 6 août)	Exfiltrations déjà faites ; coupure définitive d'ADER (13 août) et du PIGP (18 août) pour les agents

Enseignements sur la gestion des comptes et des flux

- **Pas d'authentification multifacteur** sur le PIGP et ADER : identifiants volés réutilisables tout de suite ; le code par courriel d'**APEX** s'est révélé insuffisant.
- **Analyse post-compromission** : chaque compte compromis devrait faire l'objet d'une analyse de son activité sur toute la période d'exposition (coûteux en temps).
- **Corrélation** : volume échangé, requêtes par utilisateur, IP suspectes, connexions nocturnes : chaque signal seul donne de fausses alertes, leur corrélation aurait alerté.
- **Accès aux données** : des comptes non privilégiés avaient accès à un volume important de données (objet d'un audit organisationnel phase deux).
- **Filtrage des flux** : un filtrage plus fin des flux entre ministères doit être engagé.
- **Blocage au RIE** : suppose au préalable une cartographie plus fine des flux légitimes.
- **Détection d'exfiltration** : le volume cumulé de requêtes générées aurait dû déclencher des alertes.
- **Réinitialisation** : inutile si l'appareil infecté n'est pas nettoyé ; elle doit révoquer les sessions actives et s'accompagner d'une analyse de l'activité du compte.

Restrictions d'accès aux applications

Type d'application	Conditions d'accès
Usage interne	Postes administrés par la **DGFiP** ; via **VPN réservé aux agents** si accès depuis Internet
Usage externe limité	Réseaux internes ; **VPN pour les partenaires** ; ou liste d'**adresses IP autorisées**
Usage public	Filtrage géographique et **listes d'adresses IP mal réputées** ; authentification renforcée

Pièges et confusions

- ⚠ Confondre l'action de réinitialisation du mot de passe le 24 juin à 10h40 avec une interruption de l'exfiltration.
- ⚠ Croire que la réinitialisation du compte le 7 juin a permis de détecter le passage vers le portail ADER.
- ⚠ Confondre le nombre de particuliers concernés (353 000) avec celui de professionnels (252 000).
- ⚠ Croire à une attaque sophistiquée : ce sont des faiblesses ordinaires (identité, architecture, détection).
- ⚠ Associer le portail APEX à un usage interne plutôt qu'à un usage externe limité pour les partenaires.
- ⚠ Croire que la réinitialisation d'un mot de passe coupe les sessions déjà ouvertes.

Sigles et définitions

ANSSI	Agence nationale de la sécurité des systèmes d'information, autorité nationale en matière de cybersécurité
DGFiP	Direction générale des Finances publiques, victime des actes malveillants
RIE	Réseau interministériel de l'État, qui relie les ministères entre eux
PIGP	Portail internet de la gestion publique : ordonnateurs et comptables des collectivités, et messagerie / RH des agents
E-Contact	Application de messagerie servant aux échanges entre la DGFiP et les usagers
SPDC	Serveur professionnel de données cadastrales
Infostealer	Logiciel malveillant conçu pour voler discrètement les données, notamment les identifiants
SOC	Centre opérationnel de sécurité, chargé de surveiller, détecter et traiter les incidents
ADER	Portail d'accès à des applications de la DGFiP à travers le RIE (non supervisé par le SOC)
APEX	Portail réservé aux partenaires externes (notaires, géomètres-experts) : identifiant, mot de passe, code par courriel
COSSIM	SOC ministériel de l'Éducation nationale

Auto-test

1. Combien de Français sont concernés par l'exfiltration des données cadastrales ?
2. Quel ministère a servi de point de départ à l'attaquant via le RIE ?
3. Quel est le résultat de la réinitialisation du mot de passe effectuée le 24 juin à 10h40 ?
4. Quel portail est réservé aux partenaires externes comme les notaires ?
5. Quel type d'application nécessite un filtrage géographique et une authentification renforcée ?

Réponses : **1.** 2 000 000 · **2.** ministère de l'Éducation nationale · **3.** N'interrompt ni la session ouverte ni l'exfiltration en cours · **4.** portail APEX · **5.** Usage public

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.